

SOC Nmap 段階的ネットワークスキャン チートシート

ネットワークの全容が不明な状態から、効率的かつネットワークに過度な負荷をかけずに情報を抽出するための「3段階スキャン (Phased Scanning)」の実践ガイドです。

大原則: 全てのコマンドで `-oA` を使用し、スキャン結果を必ずファイル保存すること。

第1段階: 迅速なトリアージ (Host Discovery & Top Ports)

ネットワークに存在する「稼働ホスト」を洗い出し、主要なポートのみを高速スキャンして大まかな攻撃面（アタックサーフェス）を把握します。

1-A. Ping Sweep (ホストの発見)

コマンド

```
# ポートスキャンを行わず、ICMPやARPで稼働ホストのみを特定  
  
nmap -sn 192.168.1.0/24 -oA phase1_discovery
```

💡 Pro Tip: 生きているホストのIPリスト抽出

```
grep "Up" phase1_discovery.gnmap | awk '{print $2}' > live_hosts.txt
```

この `live_hosts.txt` を次のステップのターゲット (`-iL`) として使い回します。

1-B. 主要ポートの高速スキャン (Fast Scan)

コマンド

```
# 生きているホストに対し、頻繁に使用されるトップ100ポートのみを高速スキャン  
  
nmap -sS --top-ports 100 -iL live_hosts.txt -oA  
phase1_topports
```

第2段階: 全ポート・詳細バージョン調査 (Detailed Inspection)

第1段階で判明したホストに対し、全ポート（1～65535）を対象とし、サービスバージョンとOSを特定します。

2-A. 全TCPポート & バージョン/OS特定

コマンド

```
# 全ポート(-p-)スキャン+バージョン特定(-sV)+OS推測(-O)  
  
nmap -sS -p- -sV -O -iL live_hosts.txt -oA phase2_tcp_full
```

2-B. [重要] 主要UDPポートスキャン

攻撃者はDNS(53)やSNMP(161)などのUDPサービスをよく狙います。TCPとは別にスキャンを実行します。

コマンド	<pre># UDPは時間がかかるため、まずはトップ100ポート程度に絞るのが定石 nmap -sU --top-ports 100 -sV -iL live_hosts.txt -oA phase2_udp</pre>
------	---

第3段階: 脆弱性スクリプトスキャン (Vulnerability Scanning)

バージョン情報が判明したサービスに対し、Nmap Scripting Engine (NSE) を用いて既知の脆弱性や設定不備を診断します。

3-A. 既知の脆弱性の積極的スキャン

コマンド	<pre># --script vuln を使用し、対象ホストの脆弱性を自動探索（※許可された環境のみ） # -p オプションで、第2段階で開いていたポートに絞ると効率的 nmap --script vuln -sV -iL live_hosts.txt -oA phase3_vuln</pre>
------	---

3-B. 特定サービス向けの詳細スクリプト

コマンド	<pre># 例: SMB（ポート445）に対する列挙と脆弱性スキャンのみを実行 nmap -p 445 --script smb-enum-*,smb-vuln-* -iL live_hosts.txt -oA phase3_smb</pre>
------	--

★ 補足: SOC調査員のためのNmap運用テクニック

ログの出力形式 (-oA)	Nmapの結果は標準出力だけでは不十分です。-oA <ファイル名> を付けると、XML (.xml)、Nmap標準 (.nmap)、Grep可能 (.gnmap) の3形式で同時保存され、パースやエビデンス提出に利用できます。
速度と隠蔽 (-T)	-T4: 高速 (Aggressive)。通常業務で早く終わらせたい場合。 -T2: 低速 (Sneaky)。ファイアウォールやIDSのパケットレート制限を回避したい場合。
SYNスキャン (-sS)	デフォルトのコネクションスキャン(-sT)と異なり、3ウェイハンドシェイクを完了させない (RSTを返す) ため、ターゲットのアプリケーションログに残りにくい「ステルススキャン」です。（実行には root/Administrator 権限が必要）